

Nexus Document Platform 4.2 — Security Architecture

Authentication

The REST API uses OAuth 2.0 access tokens. Tokens are validated at the API Gateway. Internal service-to-service calls use short-lived service credentials. The WPF client stores refresh tokens using the operating system credential store.

Authorization

Users are assigned roles such as Viewer, Contributor, Operator, and Administrator. Document access is checked using tenant, role, and document classification metadata.

Data Protection

TLS 1.2 or later is required for network communication. Sensitive configuration values must be provided through environment variables or a managed secret store. Passwords and access tokens must never be written to application logs.

Audit

Authentication failures, authorization failures, document downloads, metadata changes, and administrative actions are written to the `audit_events` table.

Incident Response

Repeated authentication failures can trigger temporary account throttling. Security events can be correlated using the `request_id` field.

Related Components

See `authentication.md`, `security-notes.txt`, `application.json`, and `audit_schema.sql`.